BWAPP Vulnerability Assessment — Complete PoC Report

> **Author**: Vedant Sareen | **Period**: Jan 2024 – July 2024

> **Scope**: All BWAPP vulnerabilities across Low / Medium / High difficulty

> **Purpose**: CEH Practical prep

📋 What This Report Covers

This report documents a comprehensive vulnerability assessment of **bWAPP (Buggy Web Application)**, a deliberately insecure PHP application. Every vulnerability has been tested across all three security levels with documented PoC exploits, CWE references, and remediation recommendations aligned with **OWASP Top 10**.

🗂️ Vulnerability Index

#	Category	OWASP	CWE	Status
1	HTML Injection	A03	CWE-79	✅
2	iFrame Injection	A03	CWE-79	✅
3	OS Command Injection	A03	CWE-78	✅
4	PHP Code Injection	A03	CWE-94	✅
5	SQL Injection (GET/POST)	A03	CWE-89	✅
6	SQL Injection (Login)	A07	CWE-89	✅

#	Category	OWASP	CWE	Status
7	Blind SQL Injection	A03	CWE-89	✅
8	XSS Reflected	A03	CWE-79	✅
9	XSS Stored	A03	CWE-79	✅
10	XSS DOM-Based	A03	CWE-79	✅
11	CSRF	A01	CWE-352	✅
12	File Inclusion (LFI/RFI)	A05	CWE-73	✅
13	Unrestricted File Upload	A05	CWE-434	✅
14	XXE Injection	A05	CWE-611	✅
15	SSRF	A10	CWE-918	✅
16	Broken Auth & Session Mgmt	A07	CWE-287	✅
17	IDOR	A01	CWE-639	✅
18	Clickjacking	A05	CWE-1021	✅
19	HTTP Response Splitting	A03	CWE-113	✅
20	SSI Injection	A03	CWE-97	✅

🛠️ Tools Used

- **Burp Suite** — request interception & manipulation
- **SQLMap** — automated SQL injection
- **OWASP ZAP** — automated vulnerability scanning
- **Nikto** — web server scanning
- **Browser DevTools** — DOM/JS analysis
- **Manual Testing** — custom payloads

📊 Severity Summary

Severity	Count
🔴 Critical	6
🟠 High	7
🟡 Medium	5
🟢 Low	2

> 📁 Each sub-page below contains the full PoC for that vulnerability across all 3 difficulty levels.

🧪 01 — HTML Injection (Reflected & Stored)

🧪 02 — OS Command Injection

🧪 03 — SQL Injection (GET, POST, Login, Blind)

🧪 04 — XSS (Reflected, Stored & DOM-Based)

🧪 05 — CSRF (Cross-Site Request Forgery)

🧪 06 — File Inclusion (LFI & RFI)

🧪 07 — Unrestricted File Upload

🧪 08 — Broken Authentication & Session Management

🧪 09 — IDOR (Insecure Direct Object Reference)

🧪 10 — XXE Injection

🧪 11 — Clickjacking

🧪 12 — PHP Code Injection & SSI Injection

🧪 13 — HTTP Response Splitting & Header Injection

🧪 14 — Insecure Direct Object Reference & Missing Function Level Access

🧪 15 — Sensitive Data Exposure & Insecure Cryptography

🧪 16 — iFrame Injection, Open Redirect & SSRF

🧪 17 — XPath Injection, LDAP Injection & Buffer Overflow

🕷️ 🧪 18 — Automated Scanning Results (ZAP + Nikto)